

NS

NetSec · CA24154

DELIVERABLE D1 · DOCUMENTATION PACK

Website & Open Directory

Architecture, design system, and admin handover
for the COST Action NetSec website.

COST ACTION

CA24154 · Networking
European Security
Knowledge

VERSION & DATE

v1.2 · May 2026

AUTHOR

Dr Arthur Laudrain
MC member  · ETH Zurich
CSS



Funded by the European Union
through COST — European Cooperation
in Science and Technology.

netsec-cost.eu

The website & directory in numbers and features

A snapshot of what **netsec-cost.eu** ships today — the people it covers, the funding it points to, the technology that holds it together, and the standards it meets.

30

Participating countries — every EU/COST state with a national representative.

49

Management-Committee members listed in the open directory.

4

Working Groups, each with a chair, vice-chair, and dedicated roadmap.

5

Grant schemes documented: STSMs, Conference, Dissemination, Training, ITC.

4 yrs

ACTION DURATION

3

UI LANGUAGES

~51 %

WOMEN ON MC

€2 100

MAX GRANT

4

ITC GRANTS

€0

MONTHLY HOSTING



Apple-style glass UI

Glassmorphic cards on a dynamic aurora background, light + dark themes.



WCAG 2.1 AA

EN 301 549-aligned; zero axe-core violations on the home page.



Mobile-responsive

Every page reflows cleanly from 4K down to a 320 px phone.



Multilingual

English authoritative; French and German variants in beta with hreflang.



Auto-sync

Weekly GitHub Actions pull bios from a Google Form and MC roster from cost.eu.



SEO-ready

Open Graph + Twitter Card + JSON-LD + sitemap + canonical URLs on every page.



GDPR-compliant

No analytics or tracking pixels; consent-gated form pipeline; full privacy notice.



Dual-licensed

Code under MIT; site copy and assets under CC BY 4.0. Reuse-friendly.

What's in this document

A self-contained reference for everyone who builds on, hands over, evaluates, or simply uses the NetSec website. Each chapter stands alone; read end-to-end for a tour, or jump in by section.

01 Overview & purpose

What the site is, who it serves, and the principles behind every design choice.

02 Architecture

Tech stack, page-by-page inventory, data-flow diagrams for the weekly sync workflows, repository layout.

03 Design system

Colour tokens, typography, components, motion budget, iconography, accessibility checklist.

04 Translation & multilingual posture

How the FR/DE beta variants work, the drift-checker workflow, what falls in/out of scope.

05 SEO & discoverability

Open Graph, Twitter Card, JSON-LD, canonical URLs, hreflang, sitemap, 404 strategy.

06 Admin guide

Every account, login, and asset the site depends on; routine tasks; escalation; handover checklist.

07 Security & DevSecOps

Threat model, coordinated-disclosure policy, GitHub-native security automation, supply-chain and operational hardening.

08 Appendix A · Accessibility standard & assessment

WCAG 2.1 AA target, EN 301 549 alignment, latest self-assessment results, known limitations, reporting route.

09 Appendix B · Licensing

The dual MIT + CC BY 4.0 model and suggested attribution.

10 Appendix C · Changelog

Per-version summary of what this documentation pack records.

How to read the diagrams

Diagrams in this document are the same Mermaid sources that live in the [docs/](#) folder of the GitHub repository. They render natively on github.com so anyone with read access can navigate the live versions there. The PDF embeds them as a frozen snapshot.

01 Overview & purpose

What the site is, who it serves, and the principles behind every choice.

What this site is

The NetSec website is the official front door of **COST Action CA24154 — Networking European Security Knowledge**, served at netsec-cost.eu. It is a static GitHub Pages deployment with two scheduled data-sync workflows and one third-party form processor. There is no database, no CMS, and no build step.

It doubles as **Deliverable D1** of the Action's Memorandum of Understanding — the open community directory that the Action committed to publishing.

Three audiences, one deliverable

Every decision in the site's design weighs three audiences against each other. A change that helps one without hurting the others is good. A change that needs to "pick a side" probably isn't ready.

The wider research community

Anyone working in or alongside European security studies. The site explains what NetSec is, who's involved, what's on the calendar, and how to engage.

Members & grant applicants

Practical resources: grant calls, the e-COST workflow, deliverables, the roadmap. The Network directory and Grants page are written for them.

External evaluators & funders

COST and the European Commission, for whom the site stands as visible evidence that Deliverable D1 has been met. Privacy compliance, accessibility statement, and licensing terms are written with them in mind.

Design principles

1. **Restraint over decoration.** White space, generous line-height, and one strong colour beat busy gradients.
2. **Glass cards as the unit of UI.** Almost every distinct piece of information sits on a glassmorphic card; they define hierarchy.
3. **Stroke icons for generic glyphs, brand icons for brands.** Same concept, same icon — every conference grant gets the same microphone; every contact item gets the same envelope.

4. **Motion is a hint, not a feature.** Hover transforms ≤ 4 px, transitions ≤ 300 ms, no parallax or scroll-jacking.
5. **British English** in all user-facing copy.
6. **Accessibility first.** Every interactive element is keyboard reachable; every colour pair meets WCAG 2.1 AA; skip-links land on `#main`.

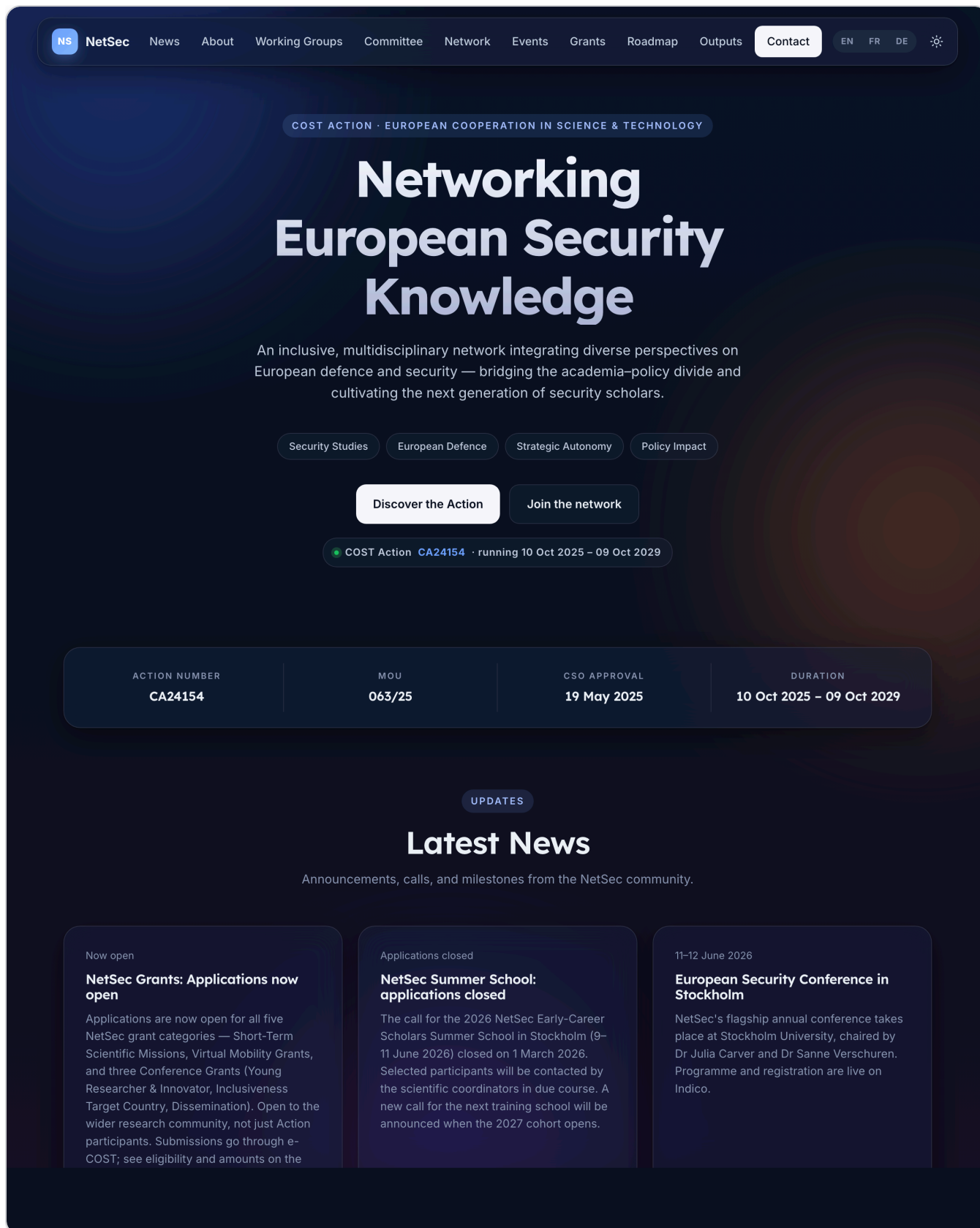


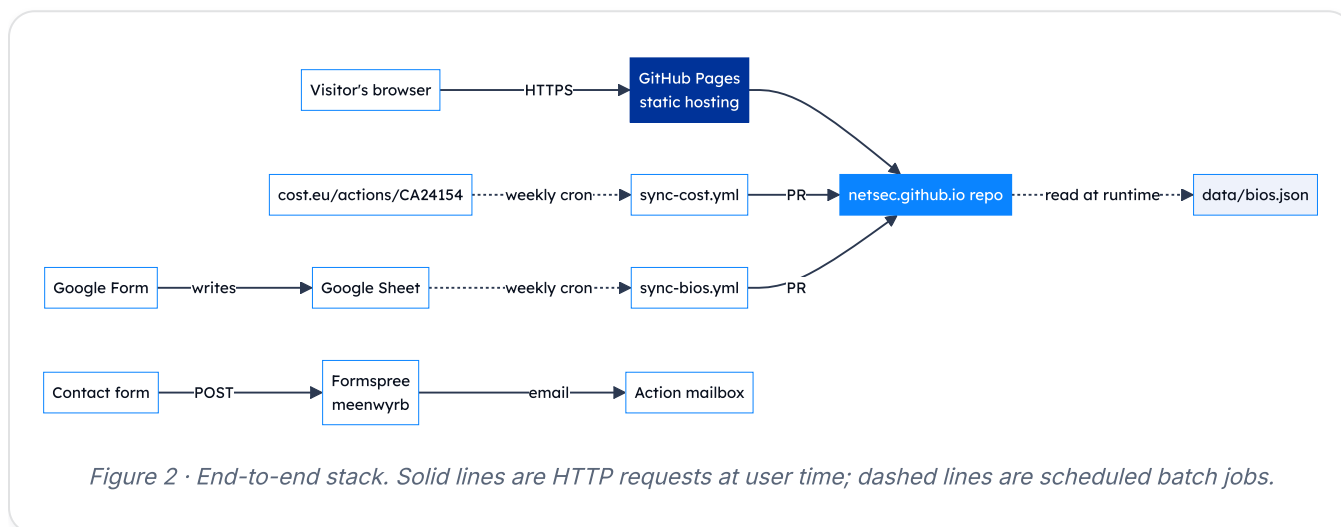
Figure 1 · Home page hero, light theme. Glass nav bar, gradient title, two CTAs, "Join the network" links straight to the open Google Form.

02 Architecture

Tech stack, pages, data flow, and repository layout.

Tech stack at a glance

The site is deliberately small. No framework, no transpiler, no bundler — just hand-authored HTML, one shared stylesheet, one shared script file, and two scheduled Python jobs that keep the data files in step with their upstream sources.

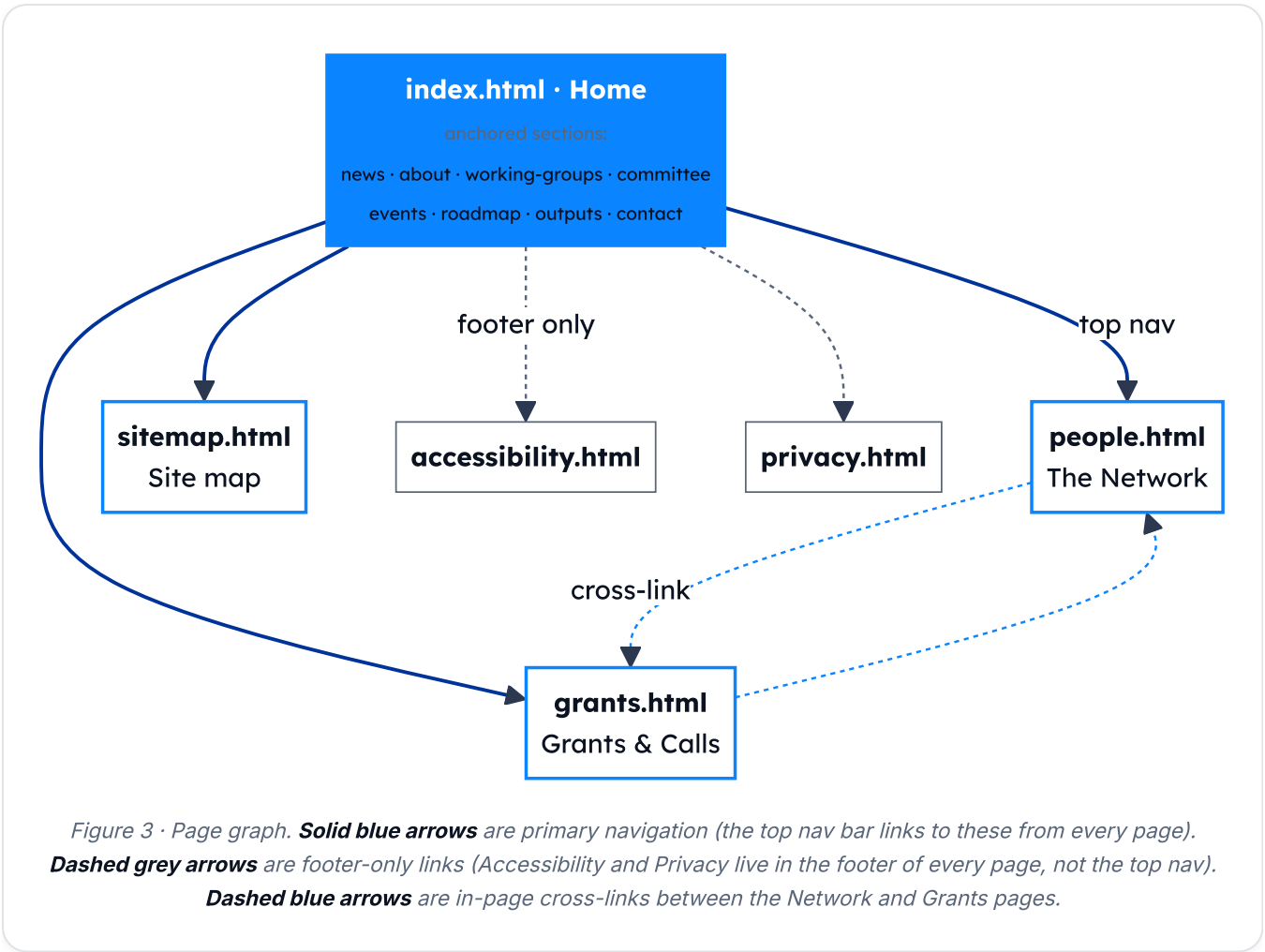


Three points to take from the diagram:

- **No back-end of our own.** Everything that looks dynamic (the directory, the grant-manager cards) is hydrated from `data/bios.json` in the visitor's browser.
- **Two sources of truth feed that file.** Member-submitted bios via a Google Form, and Action structure (WGs, leadership) via the COST website.
- **Workflow changes open a PR, never a silent push.** Every change to the directory passes through a human's review.

Site structure

Six public pages in total. The home page is the hub — it hosts most of the static content as anchored sections; three full-page applications and two statutory pages branch off it.



Page inventory

PAGE	PURPOSE	READS AT RUNTIME
<code>index.html</code>	Overview, news, WGs, Management Committee, events, roadmap, outputs, contact.	—
<code>people.html</code>	Open community directory with WG / MC / country filters; Join-the-network CTA.	<code>data/bios.json</code> (all)
<code>grants.html</code>	Five grant schemes, the e-COST timeline, resources, grant-manager contact cards.	<code>data/bios.json</code> (Grant Awarding Coordinator only)
<code>sitemap.html</code>	User-friendly site map linking every page and every in-page anchor.	—
<code>accessibility.html</code>	WCAG 2.1 conformance statement.	—
<code>privacy.html</code>	GDPR-compliant privacy notice. §10 is the licensing section.	—

Feature inventory

User-facing

- Light / dark theme with manual toggle and OS-pref default.
- Reveal-on-scroll powered by `IntersectionObserver`.
- Glass cards with `backdrop-filter`; graceful fallback.
- Country flags via FlagCDN for every ISO code (~200).
- Network directory: search × WG / MC chip × country, all AND-combined.
- Bio collapse: bios over 4 lines auto-add a "Show more" toggle.
- Awarding-process timeline with Before / During / After pills.

Operator-facing

- Two weekly sync workflows that open PRs rather than push.
- `data-bios-roles` attribute pattern — any element with it gets hydrated from `bios.json` at load.
- MC-member auto-tagging via `mc-members.json`.
- Brand-accurate social icons (Simple Icons SVGs).
- Stable slug-based member IDs for deep-linking.

Data flow — how a bio gets onto the site

The end-to-end path for a new member submission, from filling in the form to the live directory.

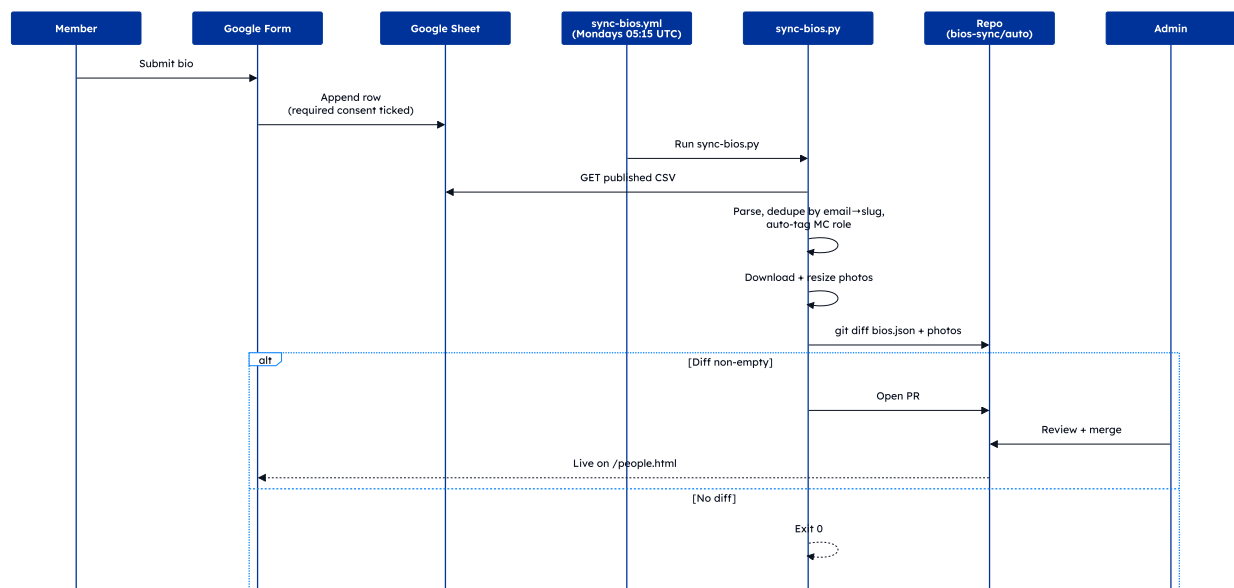


Figure 4 · Bios pipeline. Required consent on the form is what gates what reaches the Sheet. Photos are downscaled with Pillow before commit.

Data flow — how a cost.eu change propagates

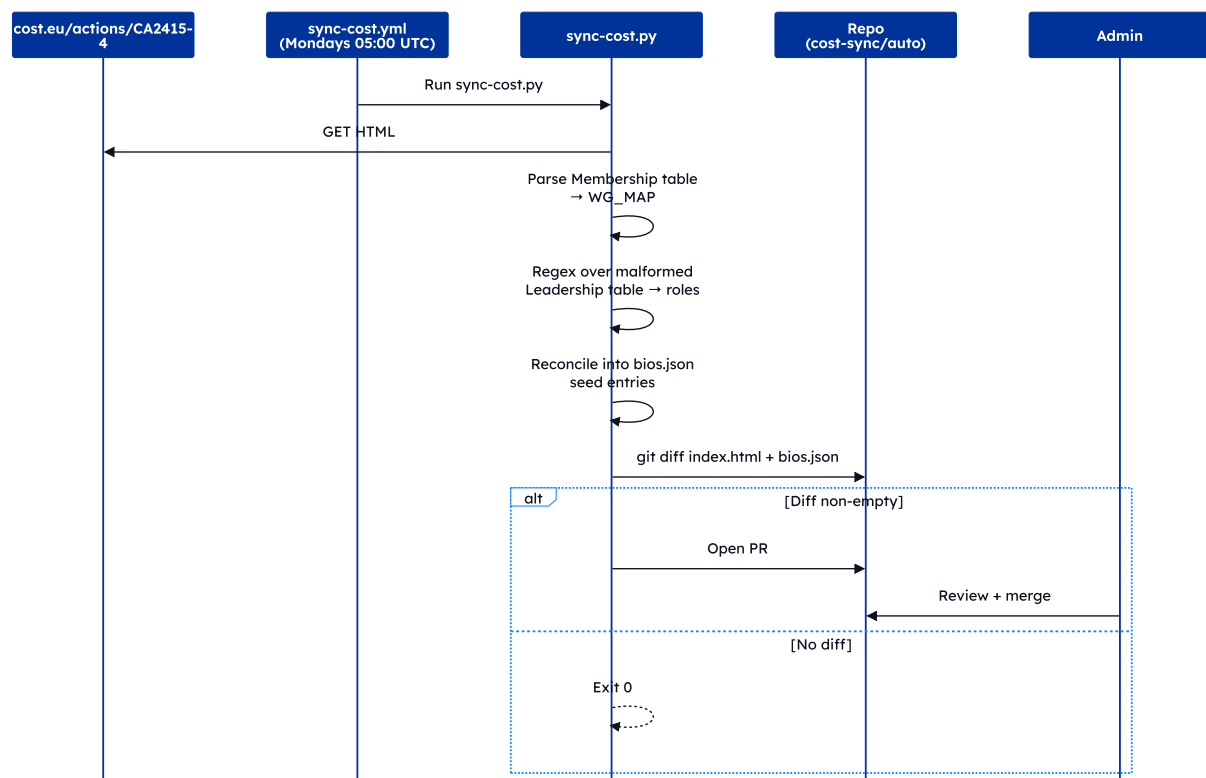


Figure 5 · cost.eu pipeline. The Leadership table on cost.eu has a malformed closing tag that breaks BeautifulSoup, so the script falls back to regex over the raw HTML.

Data flow — contact form

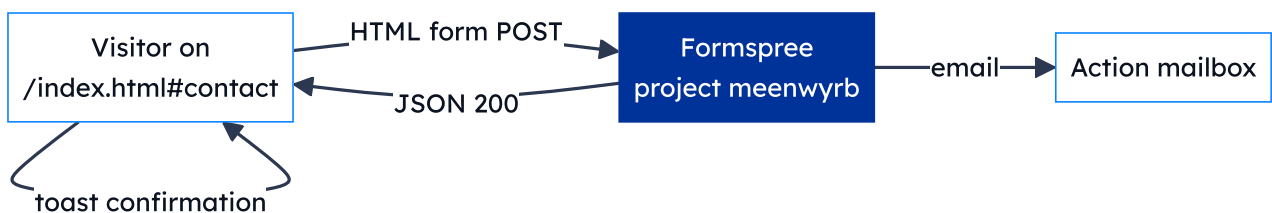


Figure 6 · Contact submissions never touch our repo. Formspree is the only third party that sees them, acting as data processor under Standard Contractual Clauses.

The Network directory in practice

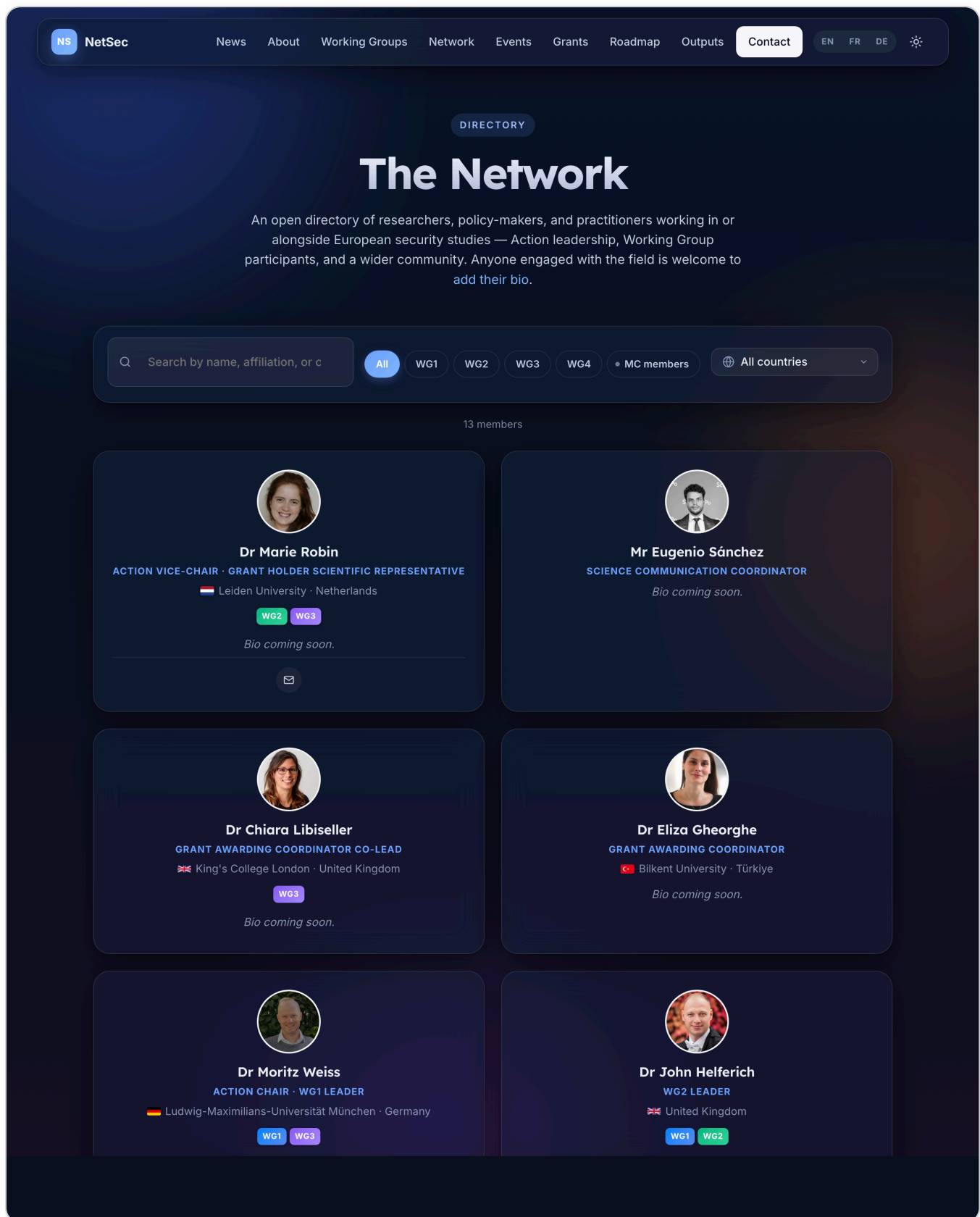


Figure 7 · The Network directory. Three filter axes — free-text search, WG/MC chip, country — AND together so they can be stacked (e.g. "MC members from France").

Repository layout

```
.
├── index.html                # Home
├── people.html              # The Network
├── grants.html              # Grants & Calls
├── accessibility.html       # WCAG statement
├── privacy.html             # GDPR notice
├── sitemap.html             # User-friendly site map
├── assets/
│   ├── css/site.css         # Single shared stylesheet
│   ├── js/site.js           # Nav, theme, reveal, accordions
│   └── images/people/*.{jpg,png} # Member headshots
├── data/
│   ├── bios.json            # The directory
│   └── mc-members.json      # MC roster per country
├── scripts/
│   ├── sync-cost.py         # cost.eu → WG_MAP + roles
│   ├── sync-bios.py         # Google Form → bios.json
│   ├── bios-source.json     # Pipeline config
│   └── requirements.txt
├── .github/workflows/
│   ├── sync-cost.yml        # Weekly cron
│   └── sync-bios.yml        # Weekly cron
├── docs/                    # Internal documentation
├── LICENSE                  # MIT (code)
├── LICENSE-CONTENT          # CC BY 4.0 (prose)
├── README.md
└── SECURITY.md
```

Conventions worth knowing

- **British English** in user-facing copy.
- **Slugs** are produced by an identical `slugify()` in both Python scripts (strip salutation, drop diacritics, drop apostrophes, lowercase, hyphenate). Both scripts must agree or member IDs drift.
- **Member IDs** are the slug of the cleaned name — stable across re-submissions, used as `id` on member cards so `/people.html#arthur-laudrain` resolves.
- **Comments in CSS / JS / Python** are full sentences explaining *why* the code is there, not paraphrasing *what* it does.
- **No JS framework, no transpiler, no bundler.** Anything more than that needs an issue first.

03 Design system

Tokens, components, motion, and the accessibility floor.

The site follows an **Apple-inspired glassmorphism** language layered onto EU and COST brand colours. It should feel modern, trustworthy, and Brussels-adjacent without ever feeling corporate.

Colour tokens

Defined in `assets/css/site.css` on `:root` (light) and `:root.dark` (dark). Always reference the token, never the raw hex.

TOKEN	LIGHT VALUE	USED FOR
<code>--bg-0</code>	<code>#f6f8fc</code>	Page background
<code>--bg-1</code>	<code>#eef2fb</code>	Slight elevation backdrop
<code>--ink</code>	<code>#0b1220</code>	Headings, primary copy
<code>--ink-2</code>	<code>#2b3850</code>	Body copy, sub-headings
<code>--muted</code>	<code>#5a6679</code>	Captions, meta, fineprint
<code>--line</code>	<code>rgba(11,18,32,.08)</code>	Dividers, low-emphasis borders
<code>--glass-bg</code>	<code>rgba(255,255,255,.55)</code>	Default glass card fill
<code>--glass-bg-strong</code>	<code>rgba(255,255,255,.72)</code>	Sticky nav, opaque cards
<code>--accent</code>	<code>#003399</code> EU blue	Primary buttons, focus rings, accents
<code>--accent-2</code>	<code>#0a84ff</code> Apple blue	Hyperlinks, secondary accent
<code>--accent-glow</code>	<code>rgba(10,132,255,.35)</code>	Soft glow under hovered buttons
<code>--ease</code>	<code>cubic-bezier(.22,.61,.36,1)</code>	Default transition curve

Dark theme inverts `--bg-*`, `--ink*`, `--line`, and `--glass-*` but keeps `--accent` and `--accent-2` identical so brand colour is constant across modes.

Typography

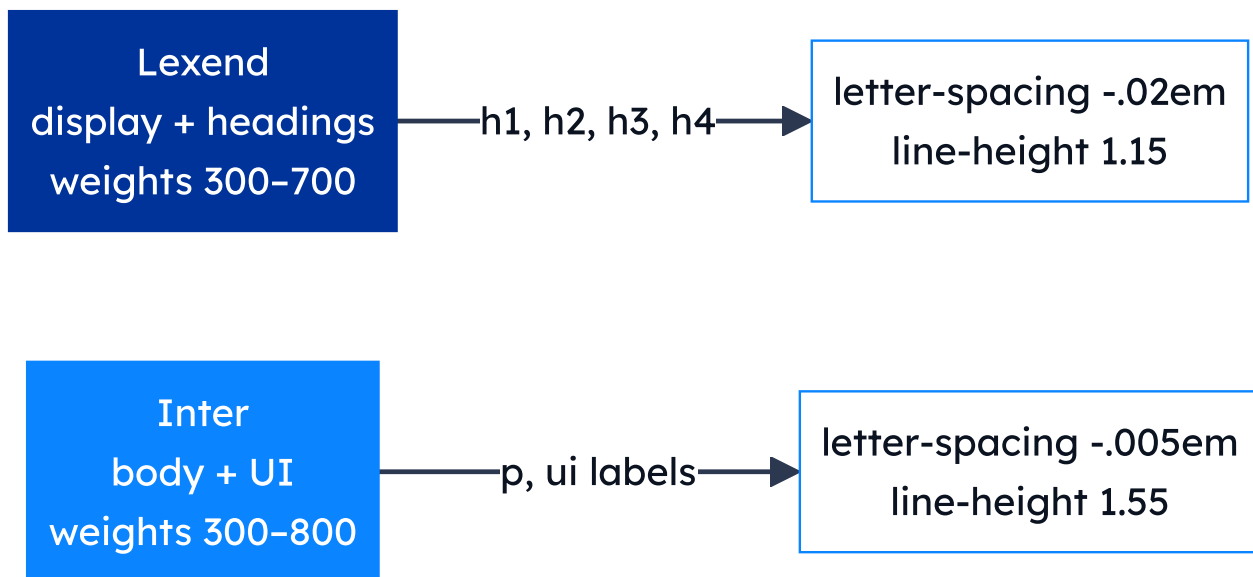


Figure 8 · Type pairing. Lexend's high x-height makes for friendly, fast-reading headlines; Inter is the most-tested body face for UI at small sizes.

Both faces load once from Google Fonts via a `<link rel="preconnect">` + stylesheet pair in every page's `<head>`. Heading hierarchy across the site:

LEVEL	COUNT	EXAMPLE
<code>h1</code>	1 per page	"The Network", "Grants & Calls"
<code>h2</code>	6–9	Major sections
<code>h3</code>	~20	Sub-sections, member names
<code>h4</code>	~18	Card titles, country names

Never skip a level (no `h2` → `h4`).

Component kit

Every distinct visual element belongs to a small, named set of CSS classes. Reuse the existing ones; don't introduce parallels.

`.glass`

The workhorse card — semi-transparent fill, blurred backdrop, soft shadow, hover lift. Used for news cards, member cards, country cards, grant cards, the search toolbar, and more.

`.btn` / `.btn-primary` / `.btn-ghost`

Primary fills with `--ink`, hover shifts to `--accent`. Ghost is transparent with a border and a slight hover lift.

`.chip` / `.wg-chip`

Pill-shaped labels. Working-Group chips are colour-coded 1–4 so a viewer can scan a member card and place them by colour alone.

`.timeline`

Vertical timeline on the Grants page — gradient rail with numbered nodes, Before / During / After phase pills, dashed-circle divider at the activity boundary.

`.mc-stats`

Three-up snapshot on the home page (49 reps, 30 countries, ~51 % women). Stacks to one column on phones.

`.members-toolbar`

Toolbar at the top of the Network page. Free-text search + WG / MC chip + country dropdown — all AND-combined by the directory's render loop.

Iconography

Two SVG styles coexist by design:

STYLE	WHEN TO USE	SOURCE
Stroke	Generic glyphs (envelope, globe, briefcase, microphone)	Lucide-style: <code>stroke="currentColor"</code> , <code>stroke-width="1.9"</code> , <code>fill="none"</code>
Filled brand	Recognisable brand marks (ORCID, LinkedIn, X, Bluesky, Mastodon)	Simple Icons SVG paths; <code>fill="currentColor"</code> (ORCID in brand green via <code>.contact-orcid</code>)

Same-concept-same-icon rule: every conference grant uses the same microphone icon; every contact-item uses the same envelope. Consistency lets users build muscle memory for what an icon means.

Motion

- `.reveal` — fades in + slides up 12 px when intersecting the viewport. Default state is *visible*; the fade only engages once JS has confirmed the observer fires. If JS fails for any reason, content stays visible — never invisible.
- `.blob` — three large translucent radial blobs in `.ambience`, drifting on a 22–34 s loop. Pure decoration; `aria-hidden="true"`.
- **Glass-card hovers** — 250 ms `translateY(-4px)` + shadow swap.
- **Theme toggle** — instant; the FOUC-prevention script runs before paint.

Accessibility checklist for new work

- All interactive controls reachable with keyboard alone.
- Visible focus ring (use the existing `:focus-visible` style).
- `aria-label` on icon-only buttons; `title` for hover hints.
- Heading levels follow the hierarchy table above — no skipping.
- Colour contrast meets WCAG 2.1 AA in **both** themes.
- No content hidden behind `:hover` alone.
- Animations respect `prefers-reduced-motion`.
- Skip-link still focuses `#top` (home) or `#main` (other pages).

04 Translation & multilingual posture

How the FR/DE beta works; how it stays in step with the English source.

The NetSec site ships in three languages: **English** (authoritative), **French** (beta), and **German** (beta). Every public page has a sibling at `page.fr.html` and `page.de.html`, surfaced through a language switcher in the header.

Budget posture

The Action has **no recurring translation budget** and no plan for a paid translation API. Translations are authored by hand, once, and refreshed only when English drifts meaningfully. The site never makes a translation API call at build or runtime.

How a language switch happens

The switcher in the header is implemented as three sibling `<a>` links — *not* a JS routing trick. Clicking *FR* on `/people.html` navigates to `/people.fr.html`. The page that gets served is the page the visitor lands on; there is no rewrite layer.

Three pieces of state cooperate:

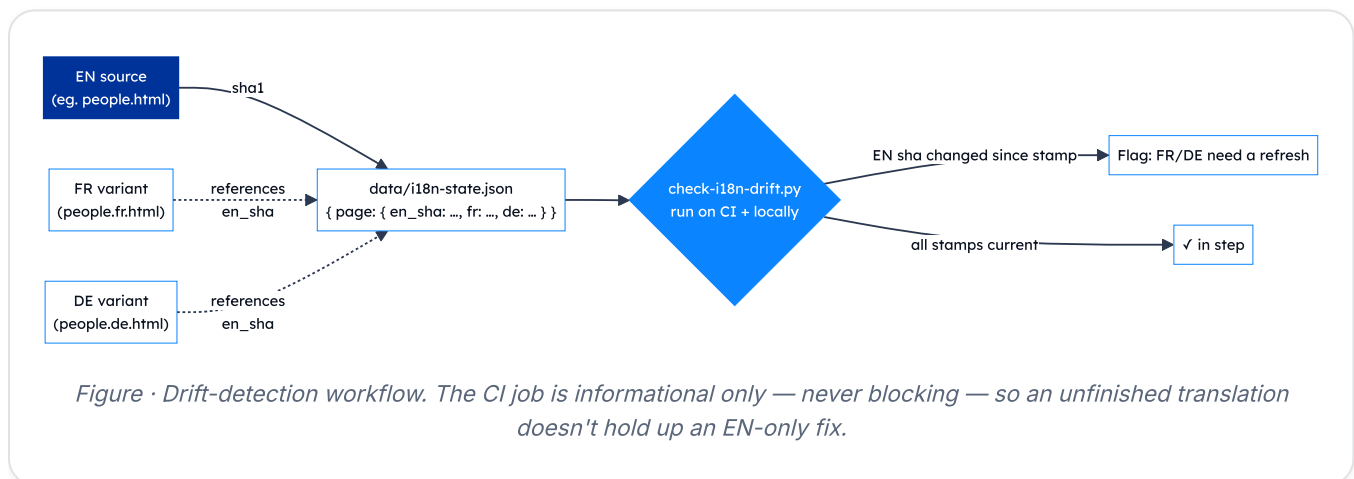
1. `<html lang="...">` on every variant — drives `:lang()` selectors and assistive-tech voice.
2. `localStorage.netsec-lang` — the visitor's saved preference. On any home-page hit (`/` , `/index.fr.html` , `/index.de.html`), `assets/js/site.js` reads this and silently redirects to the saved variant if it differs from the URL.
3. `<link rel="alternate" hreflang="...">` blocks in every page's `<head>` — tell search engines which URLs are language variants of each other (and which is `x-default`).

What's translated, what isn't

CONTENT TYPE	TRANSLATED?	WHY
Page chrome — nav, footers, headings, form labels, captions	Yes	Hand-authored in each <code>.fr.html</code> / <code>.de.html</code> file.
JS-rendered strings (search placeholder, "No results", toast confirmations)	Yes	Loaded via <code>window.netsecT()</code> from a per-locale catalog in <code>assets/js/site.js</code> .
Member-submitted bios in <code>data/bios.json</code>	No	Members write their own bio in whichever language they choose; we don't paraphrase someone else's self-description.
Calls of grants, dates, place names	No (kept in source language)	Calls are authoritative documents; translating them risks introducing error.
COST / EU boilerplate (funding statement, emblem alt-text)	Yes	Translations exist in COST's official toolkit; we reuse those.

Keeping translations in step — the drift checker

Hand-translated sibling files drift out of sync whenever English changes and the translator forgets to update FR/DE. To make that visible, we maintain a small manifest at `data/i18n-state.json` that stamps a SHA-1 of each English source page at the moment its translations were last refreshed.



Run locally:

```
python3 scripts/check-i18n-drift.py          # report which pages have drifted
python3 scripts/check-i18n-drift.py --stamp en # refresh EN sha after editing English
python3 scripts/check-i18n-drift.py --stamp fr # mark FR refreshed for changed pages
```

Refreshing a translation

1. Edit the English source (e.g. `people.html`).
2. Run the drift checker — note which pages it flags.
3. Translate the same change into `people.fr.html` and `people.de.html` by hand. Keep tag names, IDs, class names, and href targets identical; only translate text content and certain visible attributes (`title` , `aria-label` , `alt`).
4. Re-run the drift checker with `--stamp en --stamp fr --stamp de` to refresh all three.
5. Commit alongside the English change so the manifest stays meaningful.

What we deliberately don't do

- **No machine translation at build or runtime.** Quality is too uneven for an official COST deliverable, and we have no budget for an API.
- **No URL-based locale negotiation** (e.g. `/fr/people`). The static sibling-files approach keeps GitHub Pages routing simple, lets us version each translation independently, and removes any need for server-side logic.
- **No language gateway page.** The visitor lands on whichever URL they typed; client-side JS may redirect them to a saved preference, but only on the home page.

05 SEO & discoverability

Crawl directives, social-share cards, and how it all stays in sync.

The site implements the industry-standard SEO checklist for a multilingual static site: machine-readable sitemap, canonical URLs, hreflang annotations, Open Graph + Twitter Card metadata, JSON-LD structured data, and a designed 404 page. None of it is hand-typed twice — a single Python script regenerates the per-page metadata block from a small source-of-truth.

What's in place

LAYER	WHERE	WHAT IT DOES
Crawl directives	<code>robots.txt</code> at site root	<code>Allow: /</code> ; points crawlers at <code>sitemap.xml</code> . No private paths to disallow.
Discovery	<code>sitemap.xml</code> at site root	Every public page with <code><lastmod></code> , <code><changefreq></code> , <code><priority></code> , and <code>xhtml:link</code> hreflang annotations for FR/DE/x-default.
Canonical URLs	<code><link rel="canonical"></code> on every page	Points at the page's own URL — keeps the <code>.fr.html</code> / <code>.de.html</code> variants from looking like duplicates.
Language alternates	<code><link rel="alternate" hreflang></code> blocks	Matches the sitemap; explicitly declares <code>x-default</code> → English.
Open Graph	<code>og:title</code> / <code>og:description</code> / <code>og:url</code> / <code>og:type</code> / <code>og:image</code> / <code>og:site_name</code> / <code>og:locale</code>	One block per page, locale-aware.
Twitter Card	<code>summary_large_image</code>	Title / description / image mirror the OG values.
JSON-LD	<code><script type="application/ld+json"></code> per page	<code>Organization</code> schema on every page; <code>WebSite</code> on <code>/</code> ; per-page <code>WebPage</code> .
Social-share image	<code>assets/images/og-image.png</code>	1200 × 630 branded card used by Facebook, Twitter/X, LinkedIn, WhatsApp, Slack, Discord, iMessage.
Theme colour	<code><meta name="theme-color" content="#003399"></code>	Mobile browser chrome adopts the EU blue.
404 page	<code>404.html</code> at site root	Served by GitHub Pages on any unknown URL. Auto-detects browser language and points the visitor back at the right localised home. Carries <code>noindex</code> .

How it stays in sync — `inject-seo.py`

The OG / Twitter / canonical / JSON-LD blocks are **generated**, not hand-typed. The generator lives at `scripts/inject-seo.py` and is idempotent: it looks for sentinel comments (`<!-- seo:auto BEGIN -->` and `<!-- seo:jsonld BEGIN -->`) and rewrites the block in place, or inserts a fresh one between the hreflang block and `<link rel="icon">` .

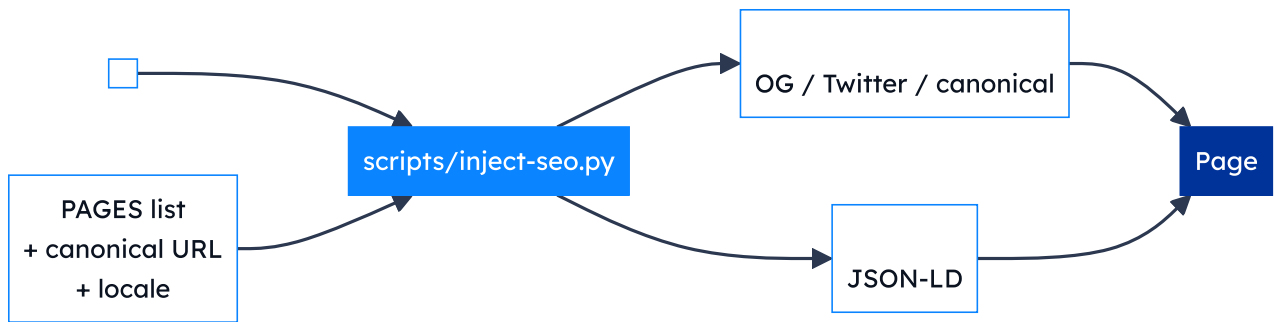


Figure · The injector reads the hand-authored title + description, combines them with per-page metadata from a `PAGES` table, and writes two sentinel-bracketed blocks into each page's `<head>` .

Use:

```
python3 scripts/inject-seo.py          # rewrites the SEO block in every HTML file
python3 scripts/inject-seo.py --check  # report-only mode (non-zero exit on drift)
```

Adding a new page

1. Hand-author a unique `<title>` (≤ 60 chars) and `<meta name="description">` (≤ 160 chars).
2. Add the `<link rel="alternate" hreflang>` block in `<head>` for EN/FR/DE/x-default.
3. Set `<html lang="...">` correctly.
4. Add the page to the `PAGES` list at the top of `scripts/inject-seo.py` , then run the script.
5. Add a `<url>` entry to `sitemap.xml` .
6. Add the page to `data/i18n-state.json` and stamp the EN SHA.
7. Run the drift checker to confirm everything is fresh.

What's deliberately *not* implemented

THING	WHY
Google Analytics / Tag Manager	Privacy posture — no third-party trackers (see privacy.html).
<code><meta name="keywords"></code>	Ignored by all major search engines for ~15 years.
AMP / amp-html	Performance budget is already very low; AMP would add complexity without measurable gain.
<code>rel="prev"</code> / <code>rel="next"</code> pagination	No paginated content on the site.
hreflang on sub-page anchors	hreflang applies to URLs, not anchors. Deep-links into a translated page inherit the page's lang.

Verifying on the live site

- **Open Graph debugger:** paste any URL into opengraph.xyz or LinkedIn's Post Inspector.
- **JSON-LD validator:** paste the URL into [Google's Rich Results test](https://search.google.com/structured-data/testing-tool/uurl/). The Organization / WebSite / WebPage nodes should all validate.
- **Lighthouse SEO audit:** any Chromium DevTools → Lighthouse. Target score ≥ 95 .

Known limits — what GitHub Pages can't do

- **No HTTP response headers.** So `Content-Language`, `Vary: Accept-Language`, and similar headers are unavailable. The `<html lang>` attribute is the next-best signal and is in place.
- **No server-side content negotiation.** Auto-redirect based on `Accept-Language` only works after the page loads. We do the redirect client-side via the saved `netsec-lang` preference, so the very first hit always lands on whatever URL the visitor typed.

06 Admin guide

Accounts, routine tasks, escalation, and handover.

This section answers: *"It's six months later, the maintainer is on parental leave, something needs editing — where do I start?"*

Accounts & assets — domain and hosting

ASSET	LOCATION	OWNER / LOGIN
<code>netsec-cost.eu</code>	Namecheap	Registered under Dr Moritz Weiss (Action Chair); admin contact Dr Arthur Laudrain
GitHub Pages routing	Repo Settings → Pages	GitHub org <code>EISSeuropa</code>
TLS certificate	Auto-managed by GitHub Pages	n/a (Let's Encrypt)

Accounts & assets — code and pipelines

ASSET	LOGIN	NOTES
GitHub repository <code>EISSeuropa/netsec.github.io</code>	GitHub account in the <code>EISSeuropa</code> org	Action Chair, Vice-Chair, maintainer.
Google Form "Join the NetSec network"	Google account that owns the form	URL stored in <code>scripts/bios-source.json</code> → <code>form_url</code> .
Linked Google Sheet	Same Google account	Publish-to-web enabled (CSV). Required-consent step on the form gates what reaches it.
Published CSV URL	n/a (public capability)	Stored in <code>scripts/bios-source.json</code> → <code>csv_url</code> . Anyone with the URL can read the Sheet — the form's required-consent step is what gates the content.
Formspree project (id <code>meenwyrb</code>)	Formspree account	Free tier; submission destination is the Action mailbox.

Bus-factor reminder

Every admin task below assumes **at least two people** hold `EISSeuropa` org membership with *Maintain* permission on the repository. If that drops to one, escalate.

Accounts & assets — branding

ASSET	LOCATION	LICENCE
COST logo	<code>assets/images/cost-logo.jpg</code>	© COST Association — used per COST visual-identity guidance.
EU emblem	Inlined SVG in every footer	Used per the EU visual-identity manual for <i>Funded by the EU</i> communication.
NetSec wordmark	Pure CSS letter-mark — no asset	© COST Action NetSec.
Member headshots	<code>assets/images/people/<slug>.*</code>	© the individual, displayed with consent.
Country flags	FlagCDN (loaded at runtime)	Flags themselves public domain; CDN MIT.

Reviewing a weekly sync PR

Both sync workflows open a pull request against `main` on a dedicated automation branch. Either may be empty most weeks — that's a feature, not a bug.

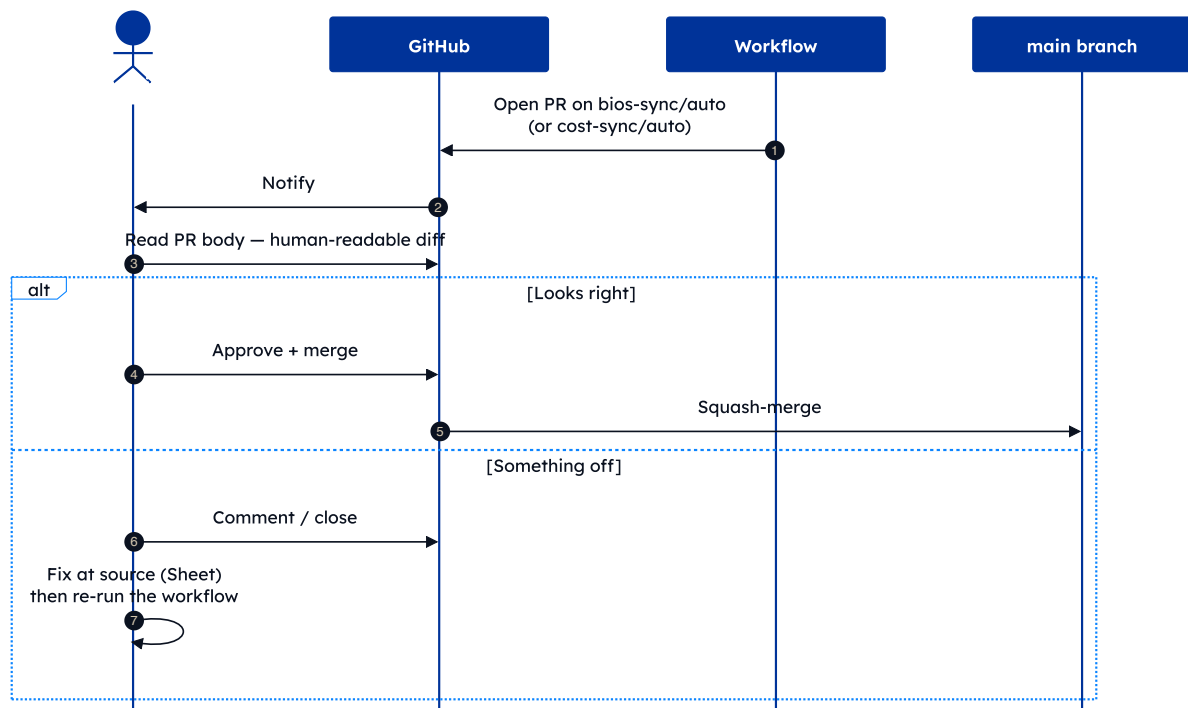


Figure 9 · Soft-review policy. No auto-merge — every new bio passes through a human's eyes.

The reviewer's job is **not** to fact-check research claims; it's to catch:

- Obvious typos (ALL-CAPS surnames, missing capitals).
- Broken or mis-targeted links (ORCID under the LinkedIn field).
- Photos that aren't headshots.
- Anyone who didn't tick consent (sync drops these automatically — but worth a glance).

Other routine tasks

Manually triggering a sync

1. Go to *Actions* in the GitHub repo.
2. Pick *Sync member bios* from *Google Form* or *Sync WG membership* from *cost.eu*.
3. Click **Run workflow** → **main** → **Run**.
4. Watch the run; if it opens a PR, review and merge.

Removing a member at their request

1. Delete the relevant `members[]` entry from `data/bios.json`.
2. Delete the headshot at `assets/images/people/<slug>.jpg` if present.
3. Open the Google Sheet and either delete the row, or clear the consent column (next sync drops them anyway).
4. Commit with message `bios: remove <slug> on request`.

Editing static page copy

1. `git checkout -b copy/<short-description>`
2. Edit the relevant `*.html` file.
3. Preview locally: `python3 -m http.server 8000` → open `http://localhost:8000`.
4. Open a PR. Merge once reviewed.

GitHub Pages rebuilds in ~30 seconds after merge.

The Grants page in practice

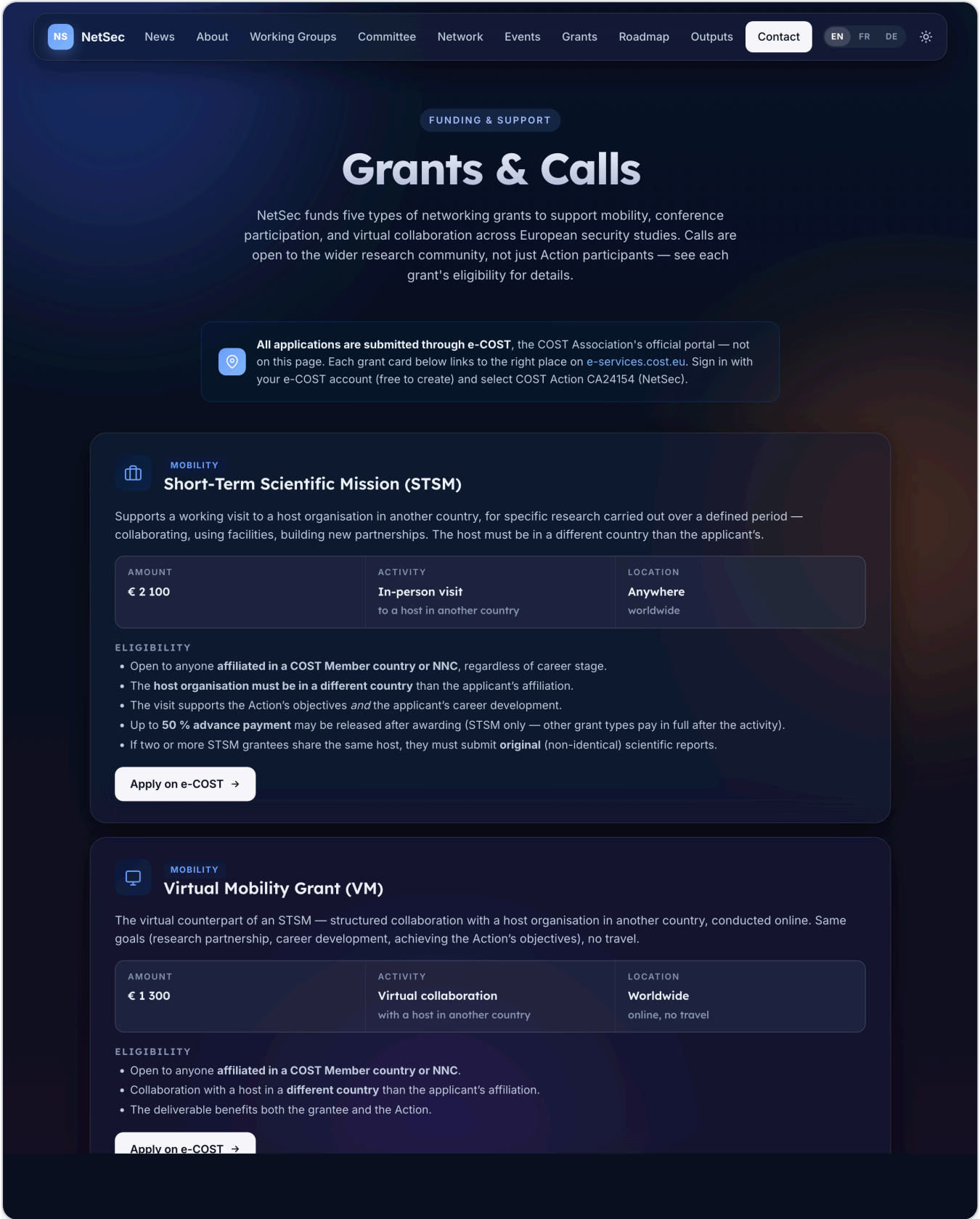


Figure 10 · Grants & Calls. All five NetSec grant schemes, with per-grant e-COST deep links and a vertical awarding-process timeline further down the page.

Escalation

SYMPTOM	FIRST PORT OF CALL
Site returns 404 / 500	githubstatus.com
Sync workflow fails	Actions tab → click the failed run → scroll to the red step
Form submissions stop arriving	Formspree dashboard
New bio doesn't appear after Monday's sync	Check Google Sheet (row present? consent ticked?) → manually trigger <i>Sync member bios</i>
Suspected security issue	Follow SECURITY.md — do not open a public issue
DNS / domain issue	Registrar admin; GitHub Pages settings as sanity check

Handover checklist

When admin responsibility moves to a new person:

- Add them to the [EISSeuropa](#) org with *Maintain* role.
- Grant them ownership of the Google Form + linked Sheet.
- Grant them access to the Formspree project.
- Make sure they have edit rights to the DNS registrar entry.
- Walk them through this document.
- Remove the previous admin's access (defence-in-depth).
- Update the *Owner / login* column above with the new owner.

07 Security & DevSecOps

Threat model, disclosure policy, GitHub-native automation, supply-chain and operational hardening.

Security is treated as a continuous practice rather than a one-time review. The full coordinated-disclosure policy lives in [SECURITY.md](#) at the repository root; this chapter summarises what is in place, what is automated, and what is the responsibility of the human admins.

Threat model in one paragraph

The site is a **static HTML deployment** with no server-side code, no database, and no authenticated user surface. The classical injection bug-classes (SQL, RCE, deserialisation, SSRF) do not apply because nothing on the server interprets user input. The realistic risk surface narrows to four areas: **(1)** the contributor pipeline — a compromised GitHub account with push access, **(2)** the two sync workflows pulling data from external sources, **(3)** the third-party processors we depend on (Formspree, Google, GitHub Pages itself), and **(4)** personal data we hold in [data/bios.json](#). The controls below are sized for that surface.

Coordinated-disclosure policy in brief

The shape of [SECURITY.md](#) :

Scope

In scope: the current [main](#) branch, the deployed site at [netsec-cost.eu](#), the two GitHub Actions, the Python sync scripts, and any personal data we hold.

Out of scope: older branches, tags, or forks; reports about COST or EU branding; volumetric DoS against third parties (GitHub, Formspree, Google). Those go to the relevant vendor.

How to report

Two private channels, never a public GitHub issue:

1. **GitHub Security Advisories** (preferred):

github.com/EISSeuropa/netsec.github.io/security/advisories/new .

2. **Email** the maintainer; for data-protection matters specifically, contact the Data Controller (Universiteit Leiden) per the addresses listed in [privacy.html](#).

What to expect

STAGE	TARGET
Acknowledgement	Within 5 working days.
Initial assessment	Within 14 working days.
Resolution — Critical	Patch in days; hotfix to <code>main</code> .
Resolution — High / Medium	Next sprint, typically 2–4 weeks.
Resolution — Low	Routine maintenance.
Disclosure	Coordinated; credit on request.

Safe harbour

Good-faith research is welcomed: act only against your own data and the public site, avoid privacy violations and service disruption, do not retain personal data of others, and give us reasonable time to fix before public disclosure.

GitHub-native security automation

The repository is enrolled in five GitHub Advanced Security features. They run continuously, with results visible under the *Security* tab.

FEATURE	TRIGGER	WHAT IT DOES
Private vulnerability reporting	Researcher submission	Offers external reporters a confidential channel inside GitHub, with end-to-end encryption and the option to collaborate on a fix in a private fork before public disclosure. Replaces the older "find an email address" route.
Security advisories	Maintainer-initiated, post-triage	Records every confirmed vulnerability as a draft advisory, links it to the fix commit, and publishes a CVE when warranted. Provides a single audit trail for evaluators.
Dependabot alerts	Continuous	Scans the dependency graph (Python <code>requirements.txt</code> , GitHub Actions versions) against the GitHub Advisory Database. Opens an issue per advisory with an upgrade path.
Code scanning — CodeQL	<code>push</code> + <code>pull_request</code> against <code>main</code> , plus a weekly cron	Runs the security-and-quality and security-extended CodeQL query suites at the <i>high-precision</i> setting, across HTML, JavaScript, Python, and GitHub Actions YAML. Findings appear as PR review comments and on the Security tab.
Secret scanning + push protection	Every push and historical sweep	Detects exposed tokens, API keys, and high-entropy strings matching known provider patterns. Push protection blocks the commit at <code>git push</code> time before the secret enters history.

Why this combination, on a static site

The site itself has almost no executable code, but the *sync* workflows execute trusted Python with broad repo-write capabilities. Treating the build pipeline as a first-class security target, rather than just the deployed pages, is what these five tools collectively achieve.

Supply-chain and CI hardening

- **Pinned third-party Actions.** All `uses:` references in `.github/workflows/` are pinned to a major version tag (and where practical, to a commit SHA), so an upstream tag retag cannot inject new code without our review.
- **Least-privilege `GITHUB_TOKEN`.** Each workflow declares the narrowest `permissions:` block it needs (`contents: write` for the sync jobs, `contents: read` elsewhere). The default token is read-only at the repository level.
- **Two-person review on `main`.** Sync workflows do not auto-merge; they open a pull request and wait for a human reviewer. New bios are explicitly reviewed before going public.
- **No long-lived deploy keys.** Deployment is handled by GitHub Pages itself, using the repository's own short-lived OIDC token, so there is no external secret to rotate.
- **Source-of-truth visibility.** Both data files (`data/bios.json` , `data/mc-members.json`) are version-controlled. Any malicious or accidental change is one `git revert` away.

Web-platform hardening

- **HTTPS everywhere.** GitHub Pages enforces HTTPS with an auto-renewed Let's Encrypt certificate. Plain-HTTP requests are redirected.
- **Strict-Transport-Security.** GitHub Pages sends a long-lived `Strict-Transport-Security` header on every response.
- **No inline secrets, no privileged scripts.** The only JavaScript on the site is the locally-hosted `assets/js/site.js` ; no third-party tag managers, analytics, or chat widgets are loaded.
- **Minimal third-party calls.** At runtime the page contacts Google Fonts (CSS only), FlagCDN (PNG only), and Formspree (only on form submit). All declared in `privacy.html` .
- **SafeHTML form handling.** The contact form posts via HTTPS to Formspree; we never echo submitted content back into a page, so there is no XSS surface from the form.

Account and access hygiene

- **Two-factor authentication** is required on every account with push access via GitHub's org-level 2FA enforcement.
- **Maintain role, not Admin,** for routine collaborators. The *Admin* role is held only by accounts that genuinely need branch-protection or settings access.
- **Defence-in-depth on handover.** The admin handover checklist (Section 06) ends with revoking the previous admin's access; nobody keeps access "just in case".

- **Branch-protection on `main`** (recommended): require pull-request review, require status checks (`pages build and deployment` , `i18n drift check` , `CodeQL`) to pass, disallow force-push.

Personal-data minimisation

The site holds minimal personal data: name, institution, country, working group(s), a short bio, optionally a photo and links. There is no email address in `data/bios.json` ; the contact form is the only mechanism for reaching a member, and it is mediated by Formspree under a Data Processing Agreement. All processing terms are spelt out in `privacy.html` ; the lawful basis is consent, captured at form submission time and revocable by request.

Audit trail

Every meaningful change to the site is a commit on `main` . Every commit links to a pull request, every pull request to the GitHub Actions run that built and deployed it, and every Security-tab event (alert, advisory, scan) timestamps an attributable user. The repository's *Insights* tab gives a single view of contributors, dependency health, and traffic.

A Appendix · Accessibility standard & assessment

What we target, how we test, what we found, and how to flag a barrier.

The full statement lives at netsec-cost.eu/accessibility.html and is the authoritative version. This appendix summarises it for evaluators reading offline.

Standards and legal framing

ASPECT	POSITION
Target conformance	WCAG 2.1 Level AA — Web Content Accessibility Guidelines, Level AA success criteria.
European harmonisation	Aligned with EN 301 549 , the European accessibility standard for ICT products and services.
Legal framework	Web Accessibility Directive 2016/2102 (EU). Each EU Member State designates its own enforcement body.
Current status	<i>Partially compliant</i> . The majority of WCAG 2.1 AA success criteria are met; the limitations listed below are tracked for a future iteration.
Statement version	v1.0 · prepared 14 May 2026 · next scheduled review 14 May 2027.

Latest self-assessment

An automated audit was performed on **14 May 2026** with [axe-core 4.10.2](#) running against every section of the home page (with all collapsible regions expanded). Results:

0	50	1
Violations	Passes	Needs manual review

The single item flagged for manual review is colour contrast on text rendered over `backdrop-filter` glass surfaces — axe-core cannot evaluate this automatically because the perceived contrast depends on what's behind the surface. Manual spot-checks confirm these surfaces meet WCAG 2.1 AA contrast in both light and dark mode.

Test methodology

The statement was prepared by self-assessment using three complementary methods:

- **Manual review** of semantic HTML, keyboard navigation, focus management, and tab order — every page walked through with the keyboard alone.
- **Automated scans** with [axe-core 4.10.2](#) against the home page with all collapsible regions expanded.
- **Manual contrast spot-checks** on glass surfaces in both light and dark mode (the one case axe-core cannot evaluate).

We re-assess after material changes to the design system or content structure, and at a minimum once per year.

Features in place

A non-exhaustive list of the accessibility affordances the site already ships:

- Semantic landmarks (`<header>` , `<nav>` , `<main>` , `<footer>`) and a clean heading hierarchy without level jumps.
- Skip-to-content link, visible on keyboard focus.
- Visible `:focus-visible` ring on every interactive control.
- `alt` text on every image; explicit `<label for>` association on every form input.
- Light and dark themes with a manual toggle; OS-level `prefers-color-scheme` as the default.
- `prefers-reduced-motion` disables decorative animations.
- The *Management Committee by Country* directory uses a native `<details>` accordion — fully keyboard- and screen-reader-accessible without bespoke ARIA wiring. Deep-links to specific country cards auto-expand the section.
- The roadmap Gantt grid uses ARIA grid roles (`role="table"` , `role="row"` , `role="columnheader"` , `role="cell"`) so assistive technology parses it as tabular data.
- Working-group chips are grouped with `role="group"` and an `aria-label` so screen readers announce them as a group rather than as loose tokens.
- Contact form: inline validation, accessible error reporting, and a confirmation toast announced via `role="status" aria-live="polite"` .

Known limitations

The following parts of the site do not yet fully meet WCAG 2.1 AA, or have constraints worth flagging:

- **Roadmap Gantt chart.** A dense data visualisation. On narrow viewports the chart requires horizontal scrolling; the scroll region is keyboard-focusable so users can pan with arrow keys (WCAG 2.1.1), but a text-only alternative summary is not yet provided.
- **Decorative animations.** Aurora background blobs and reveal-on-scroll fades are automatically disabled when the OS or browser signals `prefers-reduced-motion` . We do not currently expose a separate per-site override.

- **Third-party assets.** Country flag thumbnails are served from flagcdn.com and member headshots from the GitHub Pages CDN. Long-term availability is outside the Action's direct control; if any image becomes unavailable, the surrounding text content remains intact and informative.
- **EU emblem SVG.** The *Funded by the European Union* emblem carries an `aria-label` and `role="img"` but no long description; it is described by the surrounding boilerplate text.

Reporting a barrier

If you encounter an accessibility barrier on this website, or need any of its content in an alternative format, please get in touch:

- Email the Action Chair, Dr Moritz Weiss — moritz.weiss@gsi.lmu.de
- Or use the [contact form](#) and mention *"accessibility"* in your message.

We aim to respond within **10 working days**.

Enforcement procedure

If you are not satisfied with our response, you may contact the equality body or accessibility-compliance body in your country. Within the European Union, each Member State designates its own enforcement body under the [Web Accessibility Directive 2016/2102](#).

B Appendix · Licensing

The dual MIT + CC BY 4.0 model and suggested attribution.

The repository uses **dual licensing**, matching EU and COST open-access norms: code is permissively licensed for any reuse, content is openly licensed with an attribution requirement.

WHAT	LICENCE
Source code (HTML / CSS / JS, Python, GitHub Actions)	MIT
Site content (prose, page copy, documentation)	CC BY 4.0
Member bios and photographs	© contributors, used with consent
Third-party assets (icons, fonts, flags, COST / EU)	Their own licences — see LICENSE-CONTENT

Suggested attribution when reusing site content:

"Based on content from COST Action NetSec (CA24154), <https://netsec-cost.eu>, CC BY 4.0."

Where reusing the source code, an MIT-style attribution in your own [LICENSE](#) or [NOTICE](#) file is sufficient.

Why two licences

Source code and prose travel through different reuse channels. A permissive code licence (MIT) lets anyone fork the project and adapt the templates without an attribution wall in their UI; a content licence (CC BY 4.0) gives written work the standard open-access treatment expected by COST and the European Commission. Keeping them separate avoids accidentally over-licensing either side.

C Appendix · Changelog

What each revision of this documentation pack records.

This changelog tracks the documentation pack itself, not the website. Website history is in `git log` on `main`; releases of the documentation are tagged informally by the cover version.

v1.2 · May 2026

Current revision.

- **New Section 07 — Security & DevSecOps.** Threat model in a paragraph; coordinated-disclosure policy moved up from the appendix; full inventory of GitHub-native automation now in place (private vulnerability reporting, security advisories, Dependabot alerts, CodeQL code scanning with the security-and-quality and security-extended suites at high precision on push, pull-request, and a weekly cron, secret scanning with push protection); supply-chain hardening (pinned Actions, least-privilege `GITHUB_TOKEN`, two-person review on `main`); web-platform hardening (HTTPS-only, HSTS, no third-party trackers); account hygiene (org-level 2FA, branch protection); personal-data minimisation; audit-trail posture.
- **Appendix B split.** Security content promoted to Section 07; Appendix B now covers Licensing only, with the rationale for keeping the code and content licences separate.
- **New Appendix C — Changelog** (this page).
- **Footer version corrected** to match the cover.

v1.1 · May 2026

- **New full-bleed poster page** after the cover, summarising the website in numbers (30 countries, 49 MC members, 4 Working Groups, 5 grant schemes) and eight headline features.
- **New Section 04 — Translation & multilingual posture.** Sibling-file approach for FR/DE beta, what is and is not translated, the SHA-1 drift-checker workflow with diagram, refresh procedure, and the explicit "no machine-translation, no recurring API cost" stance.
- **New Section 05 — SEO & discoverability.** Open Graph, Twitter Card, JSON-LD, canonical URLs, hreflang, sitemap, 404 strategy; the `inject-seo.py` idempotent generator with diagram; new-page SEO checklist; GitHub Pages header limits.
- **DNS row clarified** — Namecheap, registered under Dr Moritz Weiss (Action Chair), with Dr Arthur Laudrain as admin contact.
- **Screenshots refreshed** against the current site (post FR/DE nav-fit fix, post-ITC-grants edit).
- Admin guide renumbered from Section 04 to Section 06; cover bumped to v1.1.

v1.0 · May 2026

- **Initial release** of the documentation pack as part of Deliverable D1.

- Cover, table of contents, and six core chapters: Overview & purpose, Architecture (with data-flow diagrams for the weekly sync workflows), Design system (tokens, components, motion, accessibility floor), Admin guide (accounts, routine tasks, escalation, handover), Appendix A Accessibility (WCAG 2.1 AA target, axe-core results), Appendix B Security & Licensing (single combined appendix in this revision).
- Three site screenshots, Mermaid diagrams inlined and rendered client-side at build time.
- Build pipeline (`docs/pdf/build.sh`) using a local HTTP server plus Chrome headless `--print-to-pdf` , no external services.

NetSec — Networking European Security Knowledge · COST Action CA24154 · MoU 063/25 · Running 10 Oct 2025 – 09 Oct 2029.

Documentation v1.2 · Compiled May 2026 by Dr Arthur Laudrain (MC member, CH; ETH Zurich CSS) as part of Deliverable D1.

The views expressed are those of the Action and do not necessarily reflect those of COST or the European Union.